When Software Fabricates Assurance: Seven Design Principles for Trustworthy Governance, Risk and Compliance Systems

Name of the Track: Track 1 – Information Systems: Theory and Practice (Digital Ethics and Policy: Regulation and Compliance)

Type of Submission: Ongoing research (design science research; artifact and technical evaluation completed, naturalistic evaluation pending)

Abstract

1. Purpose

Boards, auditors and regulators rely on governance, risk and compliance (GRC) information systems for evidence that risks are identified, rated, approved and controlled. Research on these systems has examined their adoption and value. We found no study asking whether the evidence they present can itself be trusted. A code and runtime audit of an existing risk management application found that the software invented risk ratings, discarded approvals, accepted unauthenticated authority and reported failed database writes as successes. This study asks which design failures compromise the integrity of assurance evidence. It also asks which design principles prevent them, and how well an instantiation of those principles performs against the original system.

2. Design/Methodology/Approach

This is a design science study. We read the code of an existing risk management application, ran it, and recorded seven distinct ways in which it failed. Each failure was traced to theory that already explains it, from integrity models, fail-safe defaults and complete mediation to separation of duties, tamper-evident logging and the critique of audit as ritual, and a design principle was drawn from that theory. We built a new system, ERMA-GRC, on these principles. The old and new systems then faced 23 scenarios over the same stored data, under a protocol time-stamped in the project repository beforehand. Eighteen scenarios come from the audit, four go beyond it, and one was meant to fail. All deviations are reported.

3. Findings

There are 18 cases altogether that may have been created as a result of an audit test but, through the old system, the prevention of the security issue took place in 4 of these. On the contrary, ERMA-GRC managed to prevent the security breach in all 18 cases. ERMA-GRC prevents the write actions in the sessions, where the user does not have the ability to approve his record, stamps the audit trails lines in the logged-in user, but does not put down his name while detecting edit on the entry and indicating unavailability of the database as a failure. In addition to the above criteria in audit test, ERMA-GRC managed to prevent all failures except 3 out of the 4 cases, where it managed to prevent two simultaneous approvals for one record in 2 times. Storage results come from the simulation of the database and not from the actual system. The two cases where the new design was not able to block the security breach have been listed below. Although the risk indicator shows the correct state of the client on the screen, it can still connect to the server and change the state of the screen to anything it likes. Also, the person that has access to the audit key has the opportunity to manipulate the audit

trails when offline and without being caught once the server restarts. Principles depend on each other because the reliability of the audit depends on the separation of duties.

4. Originality/Value

We treat the integrity of assurance evidence as something a GRC system's design can protect or destroy, rather than as an organisational outcome. This paper provides a taxonomy of failures observed in a working system, seven principles together with two testable propositions towards a design theory, and a scenario protocol that others can rerun. They may utilize these principles in the form of actions. These two problems identified in the design lead to the three exercises as follows: external anchoring of the audit trail from the system; calculation of the entire metrics from the server, and the test of the principles with the practitioners.

Keywords

assurance integrity; GRC information systems; design science research; enterprise risk management; tamper-proof audit trail; separation of duties